

PLAN DE RESPUESTA A INCIDENTES DE RANSOMWARE

TechCo - Cyber Incident Response Plan



Marco de Operación y Playbook de Remediación – Empresa TechCo

Control del Documento

Título del Documento	Plan de Respuesta a Incidentes de Ransomware – TechCo
Versión	1.0
Fecha de Emisión	24 de Septiembre de 2026
Estado	Final / Por Aprobado
Propietario del Documento	Equipo de Seguridad de la Información (CIRT TechCo)
Categoría del Sujeto	Gestión de Respuesta a Incidentes de Ciberseguridad
Clasificación de Acceso	CONFIDENCIAL / SOLO USO INTERNO

1. Introducción

1.1. Descripción General

En caso de un incidente de ciberseguridad, es fundamental que TechCo pueda responder de manera rápida y efectiva para limitar los impactos en la prestación de sus servicios en la nube, salvaguardar la reputación corporativa y mantener la confianza de los clientes. El presente Plan de Respuesta a Incidentes proporciona un marco estandarizado y operativo para la gestión y remediación sistemática de ataques por ransomware.

1.2. Propósito

El propósito de este Playbook es definir las actividades obligatorias que deben ejecutarse durante la detección, análisis, contención, erradicación y recuperación frente a un evento de ransomware. Asimismo, establece la asignación de responsabilidades entre el equipo de respuesta técnica (Core IT CIRT) y el equipo directivo/ampliado (Extended CIRT).

1.3. Definición de Ransomware

El ransomware es un software malicioso, mediante el cual un ente atacante bloquea o cifra los datos de los sistemas informáticos de la organización víctima, para exigir el pago de un rescate financiero a cambio de la clave de descifrado. En la evolución reciente de estas amenazas, los atacantes combinan el cifrado de archivos con la exfiltración masiva de información confidencial para ejercer una doble extorsión bajo amenaza de publicación.

1.4. Alcance

Este documento está diseñado prioritariamente para el personal de primera respuesta (Service Desk, administradores de sistemas y analistas de ciberseguridad). No opera de manera aislada, sino que se integra directamente con el Plan General de Respuesta a Incidentes de Ciberseguridad (CIRP), el Plan de Continuidad del Negocio (BCP) y los protocolos de exfiltración de datos.

1.5. Ciclo de Revisión

Este documento debe ser revisado para verificar su vigencia por el líder del CIRT de TechCo al menos una vez cada 12 meses, o inmediatamente después de la ocurrencia de un incidente mayor o modificación sustancial en la arquitectura de red y sistemas.

1.6 Suposiciones

Debido a la condición de documento educativo tomaremos algunas suposiciones:

- Se hicieron todos los cambios en la políticas de seguridad de la empresa que permitan las acciones propuestas en este documento a raíz del evento origina del ransomware (ejemplo: respaldo unico on premise, políticas de gestión de red deficientes).
- La empresa implementó correctamente un SIEM.

2. Fase de Preparación

La fase de preparación tiene como objetivo asegurar que la organización cuente con los controles técnicos, la arquitectura resiliente y el personal capacitado para responder eficazmente antes de que se presente un incidente.

2.1. Objetivos de la Fase

- Preparar la infraestructura y al personal para responder ante un ataque de ransomware de forma oportuna y coordinada.
- Garantizar que todos los empleados conozcan sus responsabilidades de reporte inmediato y prevención de amenazas.

2.2. Actividades de Preparación Técnica

- **Despliegue de EDR y Anti-Malware Centralizado:** Implementar soluciones Endpoint Detection and Response (EDR) con actualización continua en la totalidad de estaciones de trabajo, servidores de archivos y servidores de bases de datos de TechCo.
- **Segmentación de Red Lógica y Zero-Trust:** Aislar la red corporativa de producción respecto a los entornos de almacenamiento y servidores de respaldos mediante Firewalls internos y VLANs dedicadas, resolviendo la deficiencia estructural observada en TechCo.
- **Arquitectura de Backups Inmutables (Air-Gapped):** Garantizar la existencia de copias de seguridad fuera de línea (air-gapped) e inmutables, asegurando que un compromiso de la red activa no afecte los medios de restauración.
- **Eliminación de Privilegios de Administración a usuarios Locales:** Restringir privilegios administrativos en endpoints de usuarios para prevenir la ejecución no autorizada de binarios y scripts dañinos.
- **Monitoreo e Integración SIEM:** Habilitar la recolección de eventos de auditoría y definir patrones de alerta de ransomware en el sistema SIEM de TechCo.
- **Planes Complementarios Predefinidos:** Establecer parámetros predefinidos dentro del Plan de Filtración de Datos (Data Leak Plan), del Plan de Interacción con Atacantes (Threat Actor Engagement Plan), así como cualquier otro protocolo que se considere necesario tomando en cuenta la experiencia del personal (énfasis en revisar este último apartado año tras año), formalizando la política institucional de no pago de rescates.

2.3. Capacitación y Concientización

- **Campañas Contra Phishing:** Capacitar obligatoriamente a los empleados sobre la identificación de ingeniería social, correos sospechosos y archivos adjuntos maliciosos (como facturas falsas, pdfs de “trabajo”, permiso de compañía, etc), practicar simulacros de campaña con periodicidad esperable de 6 meses.
- **Simulacros Operativos:** Ejecutar ejercicios de simulación a nivel táctico, operativo y ejecutivo para validar los tiempos de respuesta del CIRT.

3. Fase de Detección

3.1. Objetivos de la Fase

- Detectar y reportar oportunamente cualquier brecha de confidencialidad, integridad o disponibilidad en los datos de TechCo.
- Realizar la investigación e identificación inicial de la amenaza de ransomware.
- Clasificar formalmente el incidente y movilizar al equipo de respuesta según la matriz de severidad.

3.2. Detección y Reporte

La detección en TechCo se canaliza mediante fuentes automatizadas y manuales:

- Alertas automatizadas del EDR o antivirus centralizado.
- Filtros de correo electrónico detectando cargas maliciosas.
- Reportes de usuarios al Service Desk informando bloqueo de archivos o notas de rescate.

Ante cualquier reporte, el Service Desk debe generar de forma inmediata un ticket de alta prioridad categorizado como 'Incidente de Ciberseguridad - Ransomware' e informar al líder del CIRT.

3.3. Investigación Inicial

El equipo técnico implicado (Core IT CIRT) debe recopilar los siguientes datos clave de primera instancia:

Parámetro de Evaluación	Detalle Aplicado al Caso TechCo
Línea de Tiempo del Incidente	Recepción de correo de phishing con factura adjunta maliciosa y momento de la ejecución inicial por parte del empleado.
Método de Identificación	Detección manual por imposibilidad de acceso a archivos y aparición de notas de rescate en el servidor de archivos.
Alcance de Infección Inicial	Compromiso del servidor de archivos operativo, la base de datos de clientes y los backups internos conectados a la red.
Propagación Activa	Confirmada propagación lateral sin restricciones debido a la ausencia de segmentación de red interna en TechCo.

4. Fase de Análisis

4.1. Objetivos de la Fase

- Determinar el alcance técnico exacto de la intrusión y analizar las muestras de código malicioso.
- Evaluar el impacto de los datos comprometidos (confidencialidad de clientes) y formalizar notificaciones legales.

- Elaborar el plan técnico prioritario de remediación y estrategia de comunicación.

4.2. Análisis Técnico de la Amenaza

- **Análisis en Sandbox Aislado:** Ejecutar el artefacto malicioso extraído del correo de phishing en un entorno virtual aislado para identificar la familia de ransomware, rutinas de cifrado y registro clave a modificar.
- **Extracción de IoCs:** Obtener direcciones IP de Servidores C2 (Command & Control), nombres de procesos ejecutables, hashes SHA-1 y artefactos utilizados por el atacante.
- **Preservación Forense:** Adquirir imágenes forenses del servidor de archivos y base de datos de acuerdo con estándares de cadena de custodia para respaldar acciones legales o investigación policial.

4.3. Evaluación de Impacto y Notificaciones Regulatorias

Dado que un ataque a TechCo puede afectar la base de datos de clientes con información sensible personal y financiera, se activarán de forma obligatoria los siguientes requisitos de notificación:

- **Notificación a la Autoridad de Protección de Datos (ICO / GDPR Art. 33):** En cumplimiento normativo, se debe remitir la notificación formal dentro de las **72 horas** posteriores a la confirmación de la brecha. La notificación incluirá:
 - Naturaleza de la brecha, categorías de datos personales y financieras afectadas.
 - Datos de contacto del DPO y del Líder del CIRT de TechCo.
 - Consecuencias probables sobre los clientes y medidas adoptadas para contener el incidente.
- **Notificación a Fuerzas Policiales y Entes de Ciberseguridad:** Reportar el delito de extorsión a las autoridades policiales competentes y centros de respuesta nacional.

5. Fase de Remediación

5.1. Objetivos de la Fase

- Contener la propagación del ransomware y aislar los componentes comprometidos.
- Erradicar totalmente el código malicioso, scripts y mecanismos de persistencia de la infraestructura de TechCo.
- Restaurar la operación de los servicios en la nube a un estado seguro (Business As Usual - BAU).

5.2. Acciones de Contención

- **Aislamiento Inmediato de Red:** Desconectar de forma física o lógica el servidor de archivos, la base de datos de clientes y la infraestructura de backups internos para detener el cifrado pasivo.
- **Bloqueo Perimetral de IoCs:** Bloquear en el Firewall las direcciones IP, dominios C2 y herramientas de acceso remoto (RATs) identificadas en el análisis.
- **Suspensión y Reseteo de Credenciales:** Invalidar inmediatamente todas las sesiones activas y suspender credenciales de cuentas de usuario o de servicio comprometidas.

5.3. Acciones de Erradicación

- Eliminar de forma automatizada y manual todos los ejecutables, scripts, tareas programadas y entradas de registro asociadas al malware.
- Reinstalar el sistema operativo de los servidores afectados a partir de imágenes maestras limpias y verificadas.
- Validar el cumplimiento estricto de parches de seguridad antes de autorizar la reconexión de cualquier dispositivo a la red.

5.4. Recuperación a Estado Operativo Normal (Restauración del BAU)

- **Restauración Segura de Datos:** Restaurar archivos corporativos y bases de datos desde las copias de seguridad inmutables/fuera de línea verificadas.
- **Despliegue Obligatorio de MFA:** Exigir autenticación de Doble Factor (MFA) para el restablecimiento global de contraseñas de todos los usuarios de TechCo.
- **Monitoreo Intensivo de Red:** Mantener una supervisión reforzada de tráfico de red y registros de eventos durante al menos 30 días posteriores al incidente para prevenir rebrotes.

6. Fase Posincidente

6.1. Objetivos de la Fase

- Elaborar el informe oficial post incidente detallando causas, impactos y acciones de mitigación.
- Ejecutar el proceso formal de lecciones aprendidas y gestión de problemas.
- Gestionar las comunicaciones de cierre y evaluar el bienestar del equipo de respuesta.

6.2. Informe Post Incidente y Causa Raíz

El CIRT emitirá un informe ejecutivo post incidente que abarcará:

- **Análisis de Causa Raíz (RCA):** Explicación detallada sobre cómo el correo de phishing superó los filtros iniciales y cómo la falta de segmentación facilitó la propagación masiva.
- **Evaluación de Impacto Financiero y Operativo:** Cuantificación de horas de inactividad, costos de recuperación y afectación en SLA de clientes.
- **Plan de Acción Correctiva (CAP):** Calendario vinculante para restaurar la segmentación Zero-Trust y monitoreo SIEM/EDR 24/7.

6.3. Bienestar del Personal y Comunicaciones Finales

- **Gestión de Recursos Humanos:** Revisar la carga de trabajo, horas extraordinarias y descansos compensatorios del personal técnico y de soporte involucrado en la respuesta.
- **Comunicaciones de Cierre:** Emitir comunicados finales transparentes para los clientes afectados y entes reguladores, informando el restablecimiento total y seguro de los servicios.

7. Anexo A: Resumen Operativo del Flujo de Respuesta

A continuación se sintetiza la secuencia operativa del Playbook v1.0 adaptada al caso TechCo:

Fase del Playbook	Acción Clave en TechCo	Responsables Principales
1. Preparación	Estructuración de backups inmutables, segmentación de red y capacitación phishing.	Jefatura de IT, Jefatura de Seguridad de la información
2. Detección	Reporte de nota de rescate al Service Desk y apertura de ticket prioritario.	Service Desk, Core CIRT
3. Análisis	Sandbox del correo/factura maliciosa, extracción de indicador de compromiso y notificación delegado de detección de datos (72h).	Core CIRT, Delgado de protección de datos, Legal
4. Contención	Aislamiento de red del servidor de archivos, DB y backups; bloqueo de C2.	Core CIRT, Network Team
5. Erradicación / Rec.	Re-imagen de SO, restauración desde backups limpios y despliegue de MFA.	Core CIRT, System Admin
6. Posincidente	Informe de causa raíz, lecciones aprendidas y revisión de bienestar de equipo.	Gold Command, HR, CIRT

Registro de Aprobación y Control de Firmas

Rol / Cargo	Responsabilidad en el Plan	Nombre y Apellidos	Firma	Fecha
Líder del CIRT / ISM	Aprobación técnica y gestión operativa de ciberseguridad			____/____/ 2026
Director de IT	Aprobación de infraestructura, red y respaldos			____/____/ 2026
Oficial de Protección de Datos (DPO)	Aprobación de cumplimiento normativo y privacidad			____/____/ 2026
Director Legal / Asesor Jurídico	Aprobación de aspectos legales y regulatorios			____/____/ 2026
Director General / CEO	Aprobación ejecutiva final (Gold Command)			____/____/ 2026